

Information Security Policy

Effective July 10, 2026 · Owner: Managing Member, Robert Burton (worrellburton@gmail.com) · Reviewed annually and after any material change · Scope: the operations platform (wadrlaw.com), its data, integrations, and everyone with access

after any material change · **Scope:** the operations platform Ledger Louise, LLC operates for its affiliated law practice, WADR Law PLLC (wadrlaw.com), its data, integrations, and everyone with firm access.

1. GOVERNANCE

The Managing Member owns this policy and approves access, vendors, and exceptions. Security-relevant changes to the platform are code-reviewed before deploy; the platform keeps an immutable audit log of sign-ins and data changes, reviewed when investigating anomalies.

2. IDENTITY AND ACCESS CONTROL

- Sign-in is through Google Workspace SSO; email sign-in requires a one-time verification code (2FA). New accounts receive **no access** until an administrator assigns a role.
- Access is role-based and enforced server-side on every API request: administrators (financial data, banking, destructive actions), members (day-to-day matter work), marketing (website/CRM only), and clients (scoped strictly to their own portal data).
- Removing or demoting a user takes effect platform-wide within one request (live revocation on every API call). Departures are also disabled at the Google Workspace level.
- Administrators review the user list and roles quarterly.
- Non-human/service access uses OAuth or scoped API tokens over TLS, stored as platform environment variables — never in code.

3. DATA PROTECTION

- Client data lives in a managed Postgres database (Supabase) with encryption at rest; all traffic is TLS. Public pages carry a strict Content-Security-Policy; the application is not indexed.
- File uploads are size- and type-validated before storage; document links are short-lived signed URLs.
- Payments run through Mercury and QuickBooks — the firm does not store bank credentials or card numbers.
- Signing links (engagement letters, documents) are single-purpose CSPRNG tokens with expiry, rotated on re-send and consumed on signature.

4. APPLICATION SECURITY

Every API route authenticates the request and authorizes the role before acting; interpolated identifiers are validated; rendered values are HTML-escaped; AI endpoints are rate-limited; sessions fail closed if the signing

secret is absent. Lint and unit tests run in CI on every push.

5. VULNERABILITY MANAGEMENT

Per SECURITY.md: continuous dependency scanning (Dependabot alerts + weekly update PRs, CI-verified), managed-runtime patching by Vercel/Supabase, EOL tracking, and a severity-based patch SLA (critical 72h · high 7 days · moderate 30 days).

6. ENDPOINTS

Firm work happens on devices signed into managed Google Workspace accounts. Devices must use full-disk encryption, screen lock, and automatic OS updates. Client data is accessed through the platform — not stored locally.

7. VENDORS

Approved subprocessors: Vercel (hosting), Supabase (database/storage/auth), Google Workspace (identity/email), Mercury (banking), Intuit QuickBooks (accounting), Resend (transactional email), GitHub (source control/CI), Anthropic (AI drafting features). New vendors require Managing Partner approval.

8. INCIDENT RESPONSE

1. **Detect** — audit log review, provider alerts, or a report to worrellburton@gmail.com. 2. **Contain** — revoke affected access (effective within one request), rotate exposed tokens/keys, disable affected integrations. 3. **Assess & notify** — determine scope from the audit log; notify affected clients and authorities as required by law and professional responsibility rules. 4. **Learn** — post-incident review; fixes land as code with tests.

9. DATA RETENTION AND DELETION

- **Client matter files** are retained per the engagement letter's Standard Terms: approximately five years after a matter concludes (clients may instruct longer in writing), after which they may be destroyed; files a client requests in writing are delivered or transferred to new counsel. Retention never falls below what New York professional-responsibility rules require.
- **Platform records:** deletion is two-stage — a recoverable soft delete, then an administrator-only, audit-logged hard delete. Hard-deleted records are snapshotted to a restricted retention archive and their files move to a segregated archive area, retained per the schedule and then purged.
- **Operational data:** audit logs are retained for accountability; database backups age out on the provider's point-in-time-recovery window; transactional email is retained by the email provider per its terms.
- **Requests:** clients may request deletion of their personal information (worrellburton@gmail.com); requests are honored except where professional-responsibility or legal-hold obligations require retention, and the requester is told what was retained and why.
- This schedule is reviewed annually with the rest of this policy.

10. CONTINUITY

The database is backed up automatically by Supabase (point-in-time recovery); all code and configuration are in version control; the platform redeploys from source. Loss of any single laptop causes no data loss.

